



AlgoBank
Secure Digital Finance

Politique de cybersécurité AlgoBank

Par : Kalen Turbide, Jonathan Cavanagh, Dotchiegue
Cisse, Clovis mulain Ngato, Sélasé Micheline Sosoe, Arsène
Fouegue Momo, Josué Rempart

Introduction

Qui est **AlgoBank**?

- AlgoBank est une banque en ligne fictive
- Banque digitale de nouvelle génération, spécialisée dans les services financiers entièrement dématérialisés.
- Fondée pour offrir une expérience bancaire moderne, rapide et sécurisée, basée sur l'innovation technologique.
- S'appuie sur des **algorithmes avancés**, l'automatisation et l'analyse de données pour optimiser les opérations et améliorer la qualité de service.
- Vise à devenir un **acteur de référence** dans la finance numérique grâce à la confiance, la transparence et la sécurité.
- Place la **sécurité des systèmes d'information** au cœur de sa stratégie pour protéger les clients et garantir la continuité des services

Introduction

La sécurité: un
pilier stratégique

Forteresse numérique autour des services d'AlgoBank

- ❑ **Sanctuariser** : Protection absolue des données bancaires et de la vie privée
- ❑ **Assurer** : Résilience totale et disponibilité 24/7 de nos services.
- ❑ **Maîtriser** : Proactivité face aux risques de fraude et d'espionnage.
- ❑ **Inculquer** : Création d'une culture du risque où chaque collaborateur est acteur.

Message Clé : « La sécurité est l'affaire de tous : chaque clic compte, chaque accès engage notre responsabilité. »

CONTEXTE ORGANISATIONNEL

Description d'AlgoBank

- Ouverture et gestion de comptes bancaires en ligne
- Paiements électroniques et virements internationaux
- Gestion de cartes de débit et de crédit
- Services d'épargne et d'investissement automatisés
- Support client accessible via application mobile et portail web

CONTEXTE ORGANISATIONNEL

Environnement de menaces

- Cyberattaques externes : phishing, DDoS, logiciels ransomware, tentatives d'intrusion.
- Menaces internes : erreurs humaines, mauvaise gestion des accès, abus de privilèges
- Fraude financière : usurpation d'identité, transactions frauduleuses, détournement de comptes
- Risques technologiques : pannes de serveurs, défaillances logicielles, vulnérabilités non corrigées
- Risques réglementaires : non-conformité aux lois sur la protection des données et normes bancaires

Gouvernance & équipes internes

Gouvernance et Responsabilités Internes

Acteur et responsabilité

- **Direction:** Cadre global sécurité, appétence risque, budget, nomination CISO, suivi KPI/audits
- **CISO/RSI:** Politiques, analyses risques, réponse incidents, tiers, sensibilisation
- **Gestionnaires:** Mise en œuvre opérationnelle (NFR), accès sécurisés, contrôles, formation équipes
- **Employés:** Respect procédures, protection accès, confidentialité données, signalement anomalie

La chaine de confiance

Parties externes &
Responsabilité
partagée

Acteur et responsabilité

- **Clients:** Protéger identifiants, sécuriser appareils, surveiller comptes, signaler phishing/suspect
- **Fournisseurs/Tiers:** SMSI proportionné, contrats sécurité, protection données/systèmes, notification incidents, audits

Politique de sécurité

Principes fondamentaux

- **Confidentialité**
Chiffrement AES-256 des données en transit et au repos, accès basé sur le moindre privilège et classification des données.
- **Intégrité**
Traçabilité complète des transactions, validation automatisée et sauvegardes quotidiennes testées mensuellement.
- **Disponibilité**
Infrastructure redondante avec basculement automatique, $RTO \leq 4$ h, supervision continue 24/7.
- **Conformité**
Respect PCI-DSS, RGPD, PSD2 et MiFID II avec audits réguliers.

Contrôles clés

- **Accès physique sécurisé (biométrie, vidéosurveillance)**
- **MFA + gestion centralisée des identités**
- **Réseau segmenté, IDS/IPS, VPN chiffré**
- **Formation sécurité et tests de phishing**
- **Surveillance et audit des prestataires**

Gestion Des Incidents De Sécurité



ÉTAPES DE GESTIONS DES INCIDENTS



SIGNALER : Tout comportements inhabituels via les canaux prévus.



ANALYSER : La gravité, les impacts sur les données et déterminer le niveau de risque.



CONTENIR : Isoler le système et restreindre les accès.



CORRIGER : Faire les corrections du système et remise en service progressive.



APPRENDRE : Retour sur l'expérience et ajustement des procédures.

Sensibilisation et formation

Programme de formation à la sécurité

- **Formation obligatoire dès l'entrée en fonction** : Tous les employés
- **Formation de mise à jour périodique** : Formation tous les trois mois. Ces informations permettent de maintenir un niveau de vigilance élevé dans tous les aspects.
- **Formations spécialisées selon les rôles** : Employés occupants des postes sensibles ; TI, équipe de la sécurité et de la gestion des risques
- **Suivis et amélioration continue** : Formation documentée et évaluée ; Rappels des bonnes pratiques, communication internes régulières.
- **Objectif** : Instauration d'une culture de sécurité durable.

Surveillance et révision

Surveillance de la conformité



Audits et Normes : Évaluations annuelles (ISO 27001 & Loi 25)



Surveillance Technique : Analyse automatisée des logs et détection d'intrusions (Pare-feu, IDS/IPS).



Facteur Humain : Suivi des formations et simulations de phishing pour tester la vigilance.



Indicateur de Performance (KPI) :

Temps de détection des incidents.

Taux de conformité des postes de travail.

Surveillance et révision

Agilité et Mise à
jour

Cycle de Révision :

- Révision systématique tous les 12 mois.
- Révisions exceptionnelles (changement d'infrastructure, nouvelles lois, incidents majeurs).

Le Processus de Mise à Jour :

- Analyse : Évaluation des nouveaux risques par les experts.
- Rédaction : Transformation des retours d'expérience en procédures.
- Approbation : Validation par la direction.
- Diffusion : Communication lors des formations trimestrielles.



AlgoBank
Secure Digital Finance

Merci!